TÉCNICO
UNIVERSIDADE
DE LISBOA

Advanced Network Security and Architectures

METI

Report Module 1 [EN]

Authors:
José Oliveira (103771) jose.novais.oliveira@tecnico.ulisboa.pt
Afonso Mendes (116024) afonsofmendes@tecnico.ulisboa.pt
Tiago Videira (116069) tiago.g.videira@tecnico.ulisboa.pt

Group 3

2025/2026 – 2nd Semester, P4

Contents

1 Introduction

FAZER APENAS NO FIM DOS 3 LABS

2 Network attacks and countermeasures

2.1 Objective

The main objective of this laboratory work is to study and experimentally evaluate a set of common network attacks and their corresponding countermeasures in a controlled environment using GNS3.

In particular, the following attacks are addressed:

- **MAC table overflow:** to understand how a switch can be forced to behave as a hub by saturating its MAC address table, and to evaluate mitigation mechanisms such as port security.
- **DHCP spoofing:** to demonstrate how a rogue DHCP server can provide malicious network configurations to clients, and to analyze the effectiveness of DHCP snooping as a countermeasure.
- **ARP poisoning (Man-in-the-Middle):** to perform a MitM attack by manipulating ARP tables, and to study the use of Dynamic ARP Inspection (DAI) for protection.
- **DNS spoofing:** to analyze how a victim can be redirected to a fake web server through DNS manipulation combined with ARP poisoning.
- **RIP poisoning:** to investigate how routing tables can be corrupted using forged RIP messages, leading to traffic redirection, and to explore authentication-based defenses.

Additionally, this work aims to:

- Analyze network behavior through packet captures using Wireshark;
- Interpret device-level information using Cisco IOS commands;
- Evaluate the practical feasibility and limitations of each attack;
- Compare experimental results with theoretical expectations.

2.2 MAC Table Overflow

2.2.1 Attack and Countermeasure

The MAC table overflow attack was performed using the `camov.py` script, generating a large number of frames with different spoofed MAC addresses.

As observed in Wireshark (Figure 1), a high volume of traffic with varying source addresses was captured, indicating the flooding behavior of the attack.

The switch behavior was analyzed using `show mac address-table`.

To mitigate the attack, port security was configured, limiting the number of MAC addresses per port and preventing the insertion of multiple spoofed entries.

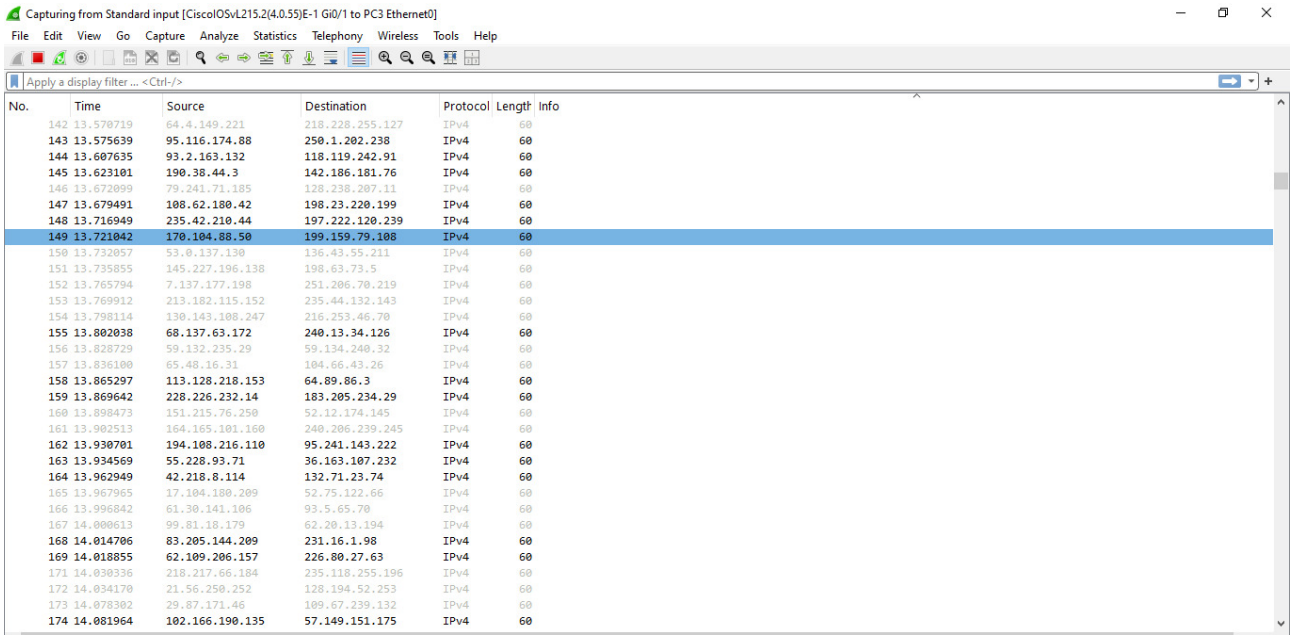

Figure 1: Wireshark capture during MAC table overflow attack

2.2.2 Switch Comparison

Cisco Catalyst 2960 supports port security, allowing the configuration of a maximum number of MAC addresses per port and defining actions when violations occur (e.g., restrict or shutdown). This makes it possible to prevent MAC table overflow attacks.

Link: www.cisco.com/c/en/us/products/switches/catalyst-2960-series-switches/index.html

In contrast, the TP-Link TL-SF1005D is an unmanaged switch that does not support port security or any traffic control mechanisms, as it lacks a configuration interface. Therefore, it cannot prevent MAC flooding attacks.

Link: www.tp-link.com/en/home-networking/soho-switch/tl-sf1005d/

2.2.3 Feasibility

The objective of this attack is to flood the switch MAC address table, forcing the switch to behave like a hub. In that state, frames may be forwarded to all ports, allowing the attacker to listen to conversations between other hosts.

However, in practice, the attack may be difficult to execute successfully on modern switches because their MAC address tables are large. Additionally, the high amount of generated traffic can cause network instability or a denial-of-service condition, instead of allowing the attacker to reliably capture useful traffic.

Therefore, although the attack is theoretically possible, its practical feasibility is limited and depends on the switch capacity, configuration, and security features.

2.3 DHCP spoofing

2.3.1 Attack and Countermeasure

The DHCP spoofing attack was performed by introducing a rogue DHCP server that responds to DHCP Discover messages with malicious configuration parameters.

As observed in Wireshark (Figure 2), multiple DHCP Offer messages were received for the same transaction ID, indicating a race condition between the legitimate and the rogue DHCP servers. The victim accepts the first Offer received, which may result in a malicious gateway configuration provided by the attacker.

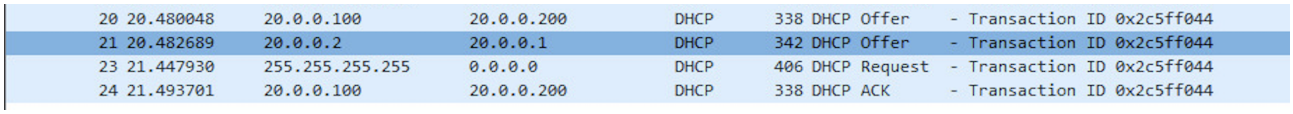

Figure 2: Wireshark capture showing multiple DHCP Offer messages (attack)

After enabling DHCP snooping and configuring the port connected to the legitimate DHCP server as trusted, only one DHCP Offer was observed (Figure 3). The rogue DHCP responses were blocked by the switch, and the client received a valid configuration. This confirms that DHCP snooping effectively mitigates the attack.

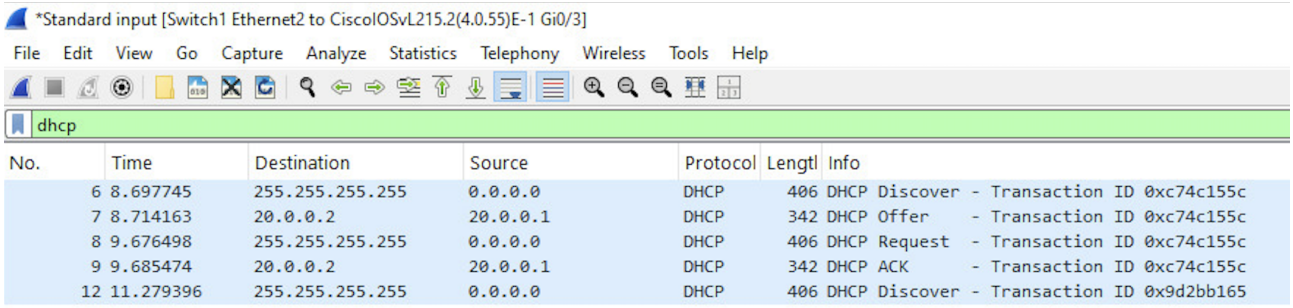

Figure 3: Wireshark capture with DHCP snooping enabled (only legitimate Offer)

2.3.2 AI Prediction

The AI predicted that the victim closer to the attacker would be more likely to be compromised, since the rogue DHCP Offer would arrive first. This prediction matched the experimental results, where the victim receiving the first Offer obtained the malicious configuration.

2.3.3 Switch Comparison

Cisco Catalyst 2960 supports DHCP snooping, allowing ports to be classified as trusted or untrusted and blocking DHCP server messages from untrusted ports.

Link: www.cisco.com/c/en/us/products/switches/catalyst-2960-series-switches/index.html

The TP-Link TL-SF1005D does not support DHCP snooping, as it is an unmanaged switch without configuration capabilities or security features.

Link: www.tp-link.com/en/home-networking/soho-switch/tl-sf1005d/

2.3.4 Feasibility

The attack is feasible in networks without DHCP snooping, especially when the attacker is closer to the victim than the legitimate DHCP server. However, due to the race condition, success is not guaranteed. When DHCP snooping is enabled, the attack becomes ineffective.

2.4 ARP poisoning (MitM)

2.4.1 Network Topology

The ARP poisoning attack was performed in the network shown in Figure 4, where two hosts communicate through a switch and an attacker is connected to the same Layer 2 domain.

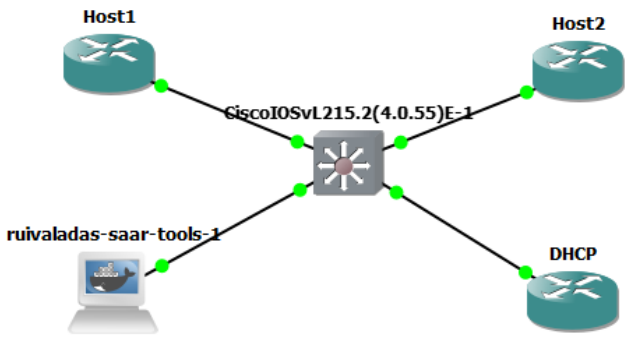

Figure 4: Network topology for ARP poisoning attack

2.4.2 Attack and Countermeasure

As observed in Wireshark (Figure 5), ARP packets indicate duplicate IP usage, confirming that the attacker is associating its MAC address with multiple IP addresses.

At the same time, ICMP traffic between the victims is still observed, which demonstrates that communication is maintained while being intercepted by the attacker, confirming a successful Man-in-the-Middle (MitM) condition.

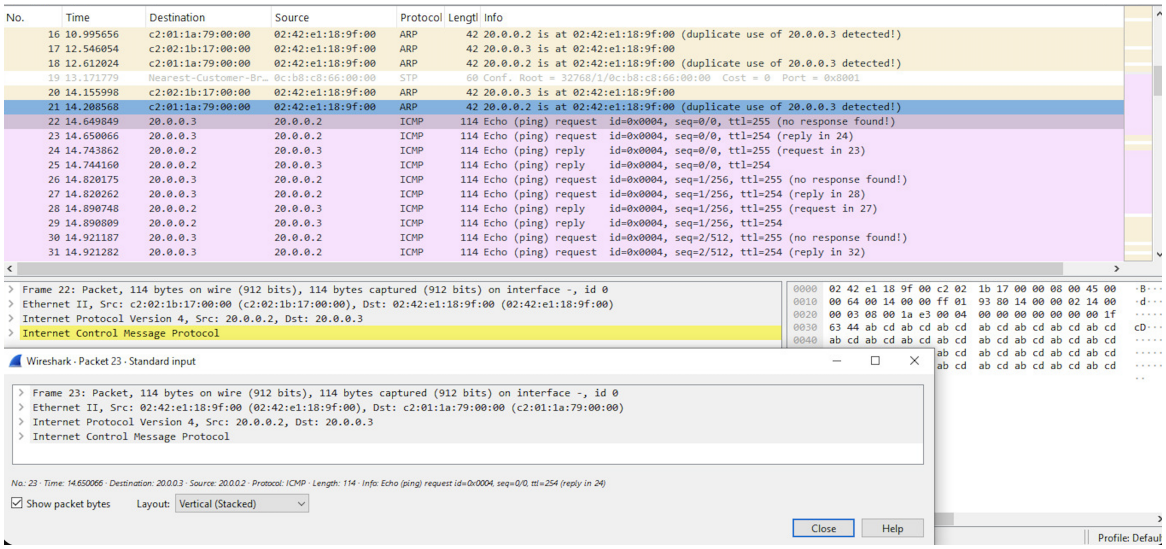

Figure 5: ARP poisoning showing duplicate IP detection and intercepted ICMP traffic

The attacker generated multiple forged ARP requests and replies, attempting to poison the ARP tables of the victims, as shown in Figure 6.

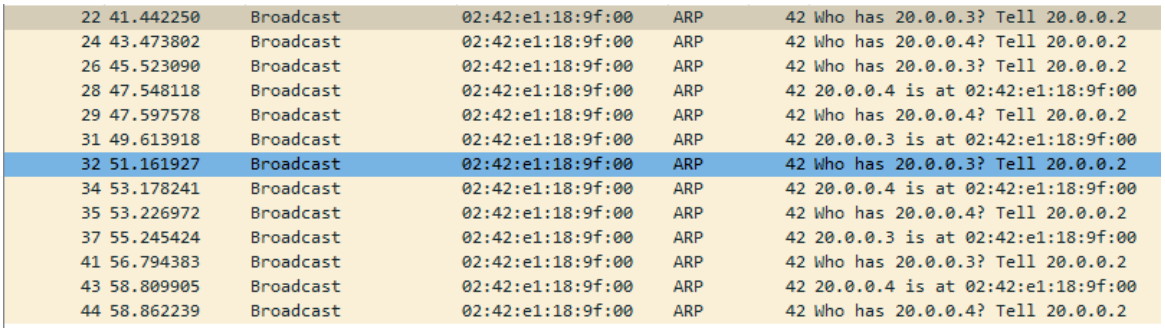

Figure 6: ARP packets generated by the attacker

However, the attack was mitigated using Dynamic ARP Inspection (DAI). The switch detected invalid ARP packets and blocked them, as shown in the system logs (Figure 7).

```
*Apr 29 10:34:18.724: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Req) on Gi0/0, vlan 1.([0242.e118.9f00/20.0.0.2/0000.000
0.0000/20.0.0.3/10:34:18 UTC Wed Apr 29 2026])
*Apr 29 10:34:20.876: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Res) on Gi0/0, vlan 1.([0242.e118.9f00/20.0.0.4/0000.000
0.0000/20.0.0.3/10:34:20 UTC Wed Apr 29 2026])
*Apr 29 10:34:20.877: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Req) on Gi0/0, vlan 1.([0242.e118.9f00/20.0.0.2/0000.000
0.0000/20.0.0.4/10:34:20 UTC Wed Apr 29 2026])
*Apr 29 10:34:23.095: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Res) on Gi0/0, vlan 1.([0242.e118.9f00/20.0.0.3/0000.000
0.0000/20.0.0.4/10:34:21 UTC Wed Apr 29 2026])
*Apr 29 10:34:24.097: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Req) on Gi0/0, vlan 1.([0242.e118.9f00/20.0.0.2/0000.000
0.0000/20.0.0.3/10:34:23 UTC Wed Apr 29 2026])
*Apr 29 10:34:25.279: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Res) on Gi0/0, vlan 1.([0242.e118.9f00/20.0.0.4/0000.000
0.0000/20.0.0.3/10:34:25 UTC Wed Apr 29 2026])
*Apr 29 10:34:25.280: %SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Req) on Gi0/0, vlan 1.([0242.e118.9f00/20.0.0.2/0000.000
0.0000/20.0.0.4/10:34:25 UTC Wed Apr 29 2026])
*Apr 29 10:34:26.622: %CDP-4-DUPLEX_MISMATCH: duplex mismatch discovered on GigabitEthernet0/3 (not half duplex), with DHCP
FastEthernet0/0 (half duplex).
```

Figure 7: DAI log showing invalid ARP packets being denied

2.4.3 Defense Statistics

The effectiveness of DAI is confirmed by the statistics shown in Figure 8, where a high number of ARP packets were dropped by the switch.

```
Switch#show ip arp inspection statistics

Vlan      Forwarded        Dropped     DHCP Drops      ACL Drops
----      ---------        -------     ----------      ---------
   1              6            259            259              0

Vlan   DHCP Permits    ACL Permits  Probe Permits   Source MAC Failures
----   ------------    -----------  -------------   -------------------
   1              6              0              0                     0

Vlan   Dest MAC Failures   IP Validation Failures   Invalid Protocol Data
----   -----------------   ----------------------   ---------------------
   1                   0                        0                       0
```

Figure 8: DAI statistics showing dropped ARP packets

2.4.4 AI Configuration vs Experimental Setup

The AI suggested enabling DHCP snooping and configuring Dynamic ARP Inspection on the switch, marking trusted interfaces accordingly.

This matched the experimental setup, where DHCP snooping was required for DAI to validate ARP packets. The configuration had to be adapted to the topology, particularly in defining trusted ports and VLAN configuration.

2.4.5 Switch Comparison

Cisco Catalyst 2960 supports Dynamic ARP Inspection, allowing validation of ARP packets based on DHCP snooping bindings.

Link: www.cisco.com/c/en/us/products/switches/catalyst-2960-series-switches/index.html

The TP-Link TL-SF1005D does not support DAI, as it is an unmanaged switch without security or inspection mechanisms.

Link: www.tp-link.com/en/home-networking/soho-switch/tl-sf1005d/

2.4.6 Feasibility

The attacker attempted to poison the ARP tables by sending forged ARP messages. The attack successfully created a Man-in-the-Middle condition, as observed in Wireshark. However, based on the switch logs and DAI statistics, these packets were detected and blocked.

Therefore, although the attack is feasible in networks without protection, in this setup it was not successful due to the correct configuration of Dynamic ARP Inspection.

2.5 DNS spoofing

2.6 RIP Poisoning

2.6.1 Network Topology

The RIP poisoning attack was performed using the topology shown in Figure 9. The Web browser, the legitimate Web server and the fake Web server are located in different subnets, with the attacker collocated with the fake Web server.

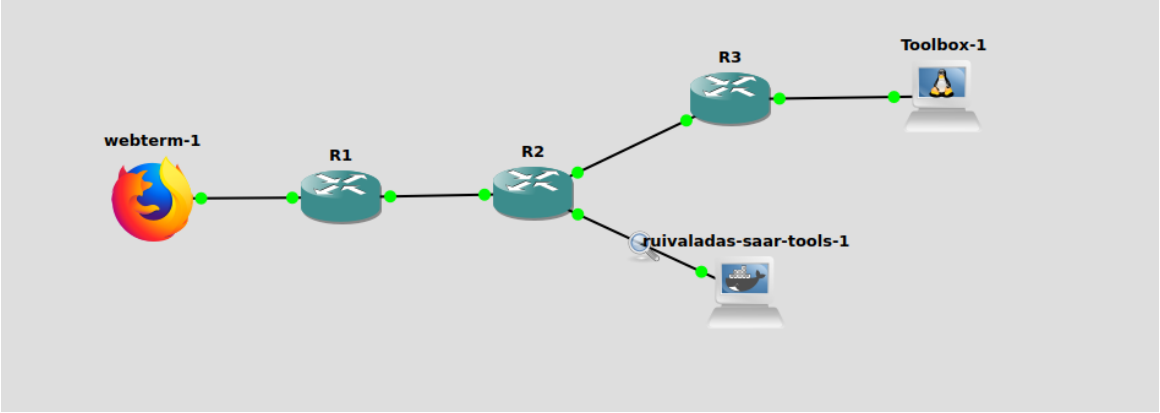

Figure 9: Network topology used for the RIP poisoning attack

2.6.2 Attack and Countermeasure

The attacker sent forged RIPv2 Response messages in order to poison the routing tables of the routers. These messages advertised a route to the legitimate Web server network through the attacker, causing traffic from the browser to be redirected to the fake Web server.

As shown in Figure 10, Wireshark captured multiple RIPv2 Response packets sent to the multicast address `224.0.0.9`, which is used by RIPv2 routers. The captured packet advertises the network `10.0.0.0` with metric 5 and subnet mask `255.255.255.128`, showing that the attacker injected routing information into the network.

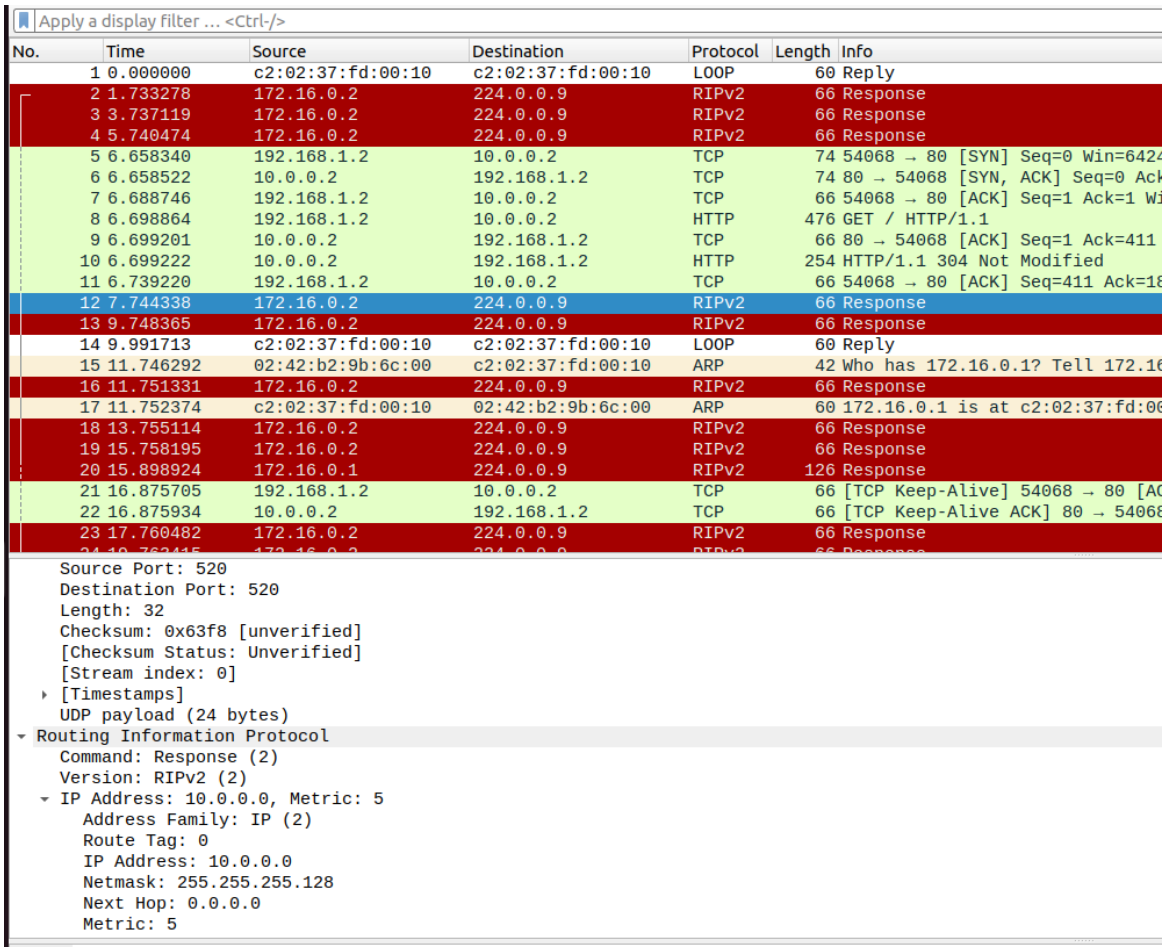

Figure 10: Forged RIPv2 response advertising a route to the target network

The effect of the attack was confirmed in the browser. As shown in Figure 11, the Web browser was redirected to the fake Web server, displaying the message *"FAKE SERVER - ATTACK SUCCESS"*.

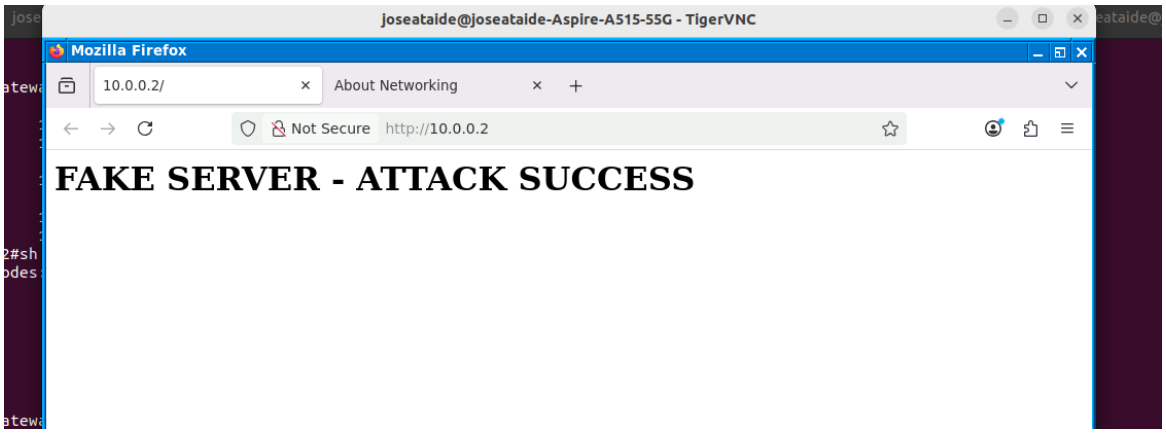

Figure 11: Browser redirected to the fake Web server

Additional Wireshark captures show TCP and HTTP communication between the browser and the fake server, confirming that the traffic was redirected after the routing tables were poisoned.

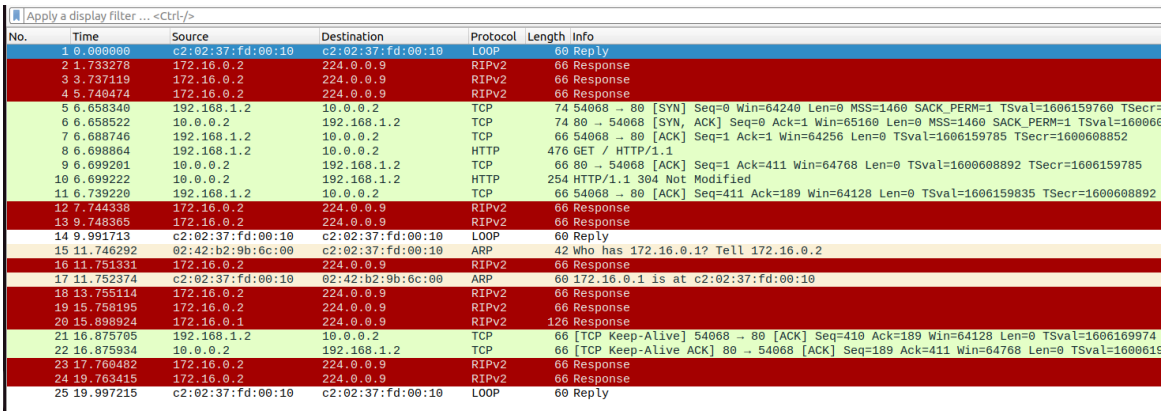

Figure 12: TCP and HTTP traffic redirected to the fake Web server

As a countermeasure, RIPv2 authentication can be enabled on the routers. With authentication, routers only accept RIP updates from trusted devices, preventing forged routing updates from being installed in the routing table.

2.6.3 Effectiveness of the Attack

The success of the attack depends on the relative location of the browser, legitimate Web server and fake Web server. Since the attacker is placed near the fake Web server, it can advertise a route that makes the fake server appear as a better path to the target network.

The prefix length advertised by the attacker is also important. A more specific prefix is preferred due to the longest prefix match rule. Therefore, if the attacker advertises a more specific route than the legitimate one, the routers may select the malicious route.

RIP auto-summary can reduce the effectiveness of the attack because it summarizes routes at classful network boundaries. When auto-summary is disabled, more specific routes can be advertised, making the attack more effective.

Figures 13 and 14 show repeated RIPv2 Response messages, confirming that the attacker continuously injected routing updates into the network.

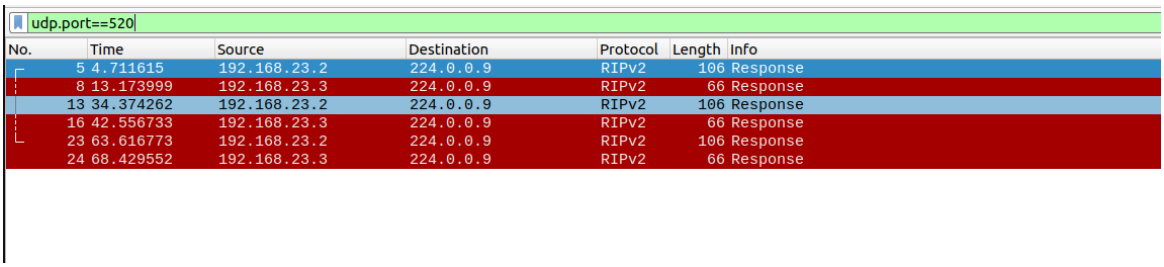

Figure 13: Filtered RIPv2 packets sent to multicast address 224.0.0.9

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	c2:02:37:fd:00:00	c2:02:37:fd:00:00	LOOP	60	Reply
2	0.268414	c2:03:38:22:00:00	c2:03:38:22:00:00	LOOP	60	Reply
3	3.282191	c2:02:37:fd:00:00	CDP/VTP/DTP/PAgP/UD…	CDP	349	Device ID: R2 Port ID: FastEthernet0/0
4	3.481026	c2:03:38:22:00:00	CDP/VTP/DTP/PAgP/UD…	CDP	349	Device ID: R3 Port ID: FastEthernet0/0
5	4.711615	192.168.23.2	224.0.0.9	RIPv2	106	Response
6	9.998962	c2:02:37:fd:00:00	c2:02:37:fd:00:00	LOOP	60	Reply
7	10.275370	c2:03:38:22:00:00	c2:03:38:22:00:00	LOOP	60	Reply
8	13.173999	192.168.23.3	224.0.0.9	RIPv2	66	Response
9	20.005237	c2:02:37:fd:00:00	c2:02:37:fd:00:00	LOOP	60	Reply
10	20.270487	c2:03:38:22:00:00	c2:03:38:22:00:00	LOOP	60	Reply
11	30.003637	c2:02:37:fd:00:00	c2:02:37:fd:00:00	LOOP	60	Reply
12	30.270107	c2:03:38:22:00:00	c2:03:38:22:00:00	LOOP	60	Reply
13	34.374262	192.168.23.2	224.0.0.9	RIPv2	106	Response
14	40.001557	c2:02:37:fd:00:00	c2:02:37:fd:00:00	LOOP	60	Reply
15	40.272070	c2:03:38:22:00:00	c2:03:38:22:00:00	LOOP	60	Reply
16	42.556733	192.168.23.3	224.0.0.9	RIPv2	66	Response
17	49.995916	c2:02:37:fd:00:00	c2:02:37:fd:00:00	LOOP	60	Reply
18	50.267336	c2:03:38:22:00:00	c2:03:38:22:00:00	LOOP	60	Reply
19	60.000765	c2:02:37:fd:00:00	c2:02:37:fd:00:00	LOOP	60	Reply
20	60.272327	c2:03:38:22:00:00	c2:03:38:22:00:00	LOOP	60	Reply
21	63.284522	c2:02:37:fd:00:00	CDP/VTP/DTP/PAgP/UD…	CDP	349	Device ID: R2 Port ID: FastEthernet0/0
22	63.475356	c2:03:38:22:00:00	CDP/VTP/DTP/PAgP/UD…	CDP	349	Device ID: R3 Port ID: FastEthernet0/0
23	63.616773	192.168.23.2	224.0.0.9	RIPv2	106	Response
24	68.429552	192.168.23.3	224.0.0.9	RIPv2	66	Response
25	69.998044	c2:02:37:fd:00:00	c2:02:37:fd:00:00	LOOP	60	Reply
26	70.272005	c2:03:38:22:00:00	c2:03:38:22:00:00	LOOP	60	Reply
27	79.995333	c2:02:37:fd:00:00	c2:02:37:fd:00:00	LOOP	60	Reply
28	80.267995	c2:03:38:22:00:00	c2:03:38:22:00:00	LOOP	60	Reply

Figure 14: Repeated RIPv2 responses observed during the attack

2.6.4 AI Prediction vs Experimental Results

The AI predicted that the attacker would be more successful when advertising a more specific prefix, because routers prefer the longest prefix match. It also predicted that disabling RIP auto-summary would make the attack more effective, since the malicious route would not be summarized.

This prediction matched the experimental behavior. The captured RIP packets show that the attacker advertised specific routing information, and the browser traffic was redirected to the fake Web server. Therefore, the observed results confirm that prefix length and auto-summary directly influence route selection.

2.6.5 Feasibility

This attack is feasible in networks using RIP without authentication. Since RIP accepts routing updates from neighboring devices, an attacker can inject forged routes and redirect traffic.

However, in modern networks, RIP is less common and authentication can prevent this attack. Therefore, the attack is mainly feasible in poorly configured or legacy networks.

3 Firewalls

3.1 Classical firewalls versus Zone-Based Policy Firewalls

3.1.1 Firewall Validation

The firewall must enforce the following rules:

1. Block all traffic from INSIDE to OUTSIDE;
2. Allow only ICMP and HTTP traffic from OUTSIDE to the server;
3. Deny access to the firewall interfaces.

3.1.2 Classical Firewall (CBAC)

In the classical firewall, traffic filtering is based on ACLs combined with stateful inspection rules. As shown in the slides, inspection rules only track sessions and do not impose restrictions by themselves.

Initially, the configuration allowed access to multiple server ports because the ACL was too permissive. This confirms that **inspect rules do not have an implicit deny**, meaning that unwanted traffic may still pass if not explicitly blocked.

After correcting the ACLs, the observed behavior was:

1. Only HTTP and ICMP traffic to the server was allowed;
2. All other ports were classified as filtered by NMAP;
3. No traffic from INSIDE to OUTSIDE was possible due to explicit deny rules.

3.1.3 ZBPF

In ZBPF, interfaces are assigned to zones and policies are applied between zones. By default, traffic between different zones is dropped unless a policy is defined.

After configuration, the firewall behavior was:

1. Only explicitly permitted traffic (HTTP and ICMP to the server) was allowed;
2. All other inter-zone traffic was blocked by default;
3. Access to firewall interfaces was denied (controlled via the self zone).

Therefore, both firewalls satisfy the specification, but ZBPF enforces it more naturally due to its default deny model.

3.2 NMAP Operation

NMAP is used to discover hosts and scan ports by actively probing the network.

3.2.1 Host Discovery

When using `nmap -sn`, NMAP determines if hosts are active by sending:

1. ICMP Echo requests;
2. TCP SYN packets to common ports (e.g., port 80);
3. ARP requests in local networks.

A host is considered active if it replies to any of these probes.

3.2.2 Port Scanning

For port scanning, NMAP typically uses a TCP SYN scan:

1. SYN-ACK response ⇒ port is open;
2. RST response ⇒ port is closed;
3. No response or ICMP error ⇒ port is filtered.

This method is efficient because it does not complete the TCP connection, allowing fast scanning of multiple ports.

3.3 CBAC vs ZBPF

The main differences between CBAC and ZBPF are:

1. **Configuration model:** CBAC is interface-based and relies on ACLs plus inspection rules, while ZBPF is zone-based and uses zone-pairs, class-maps, and policy-maps.
2. **Default behavior:** In CBAC, traffic may be allowed unless explicitly denied by ACLs. In ZBPF, traffic between zones is denied by default unless a policy allows it.
3. **Stateful inspection:** Both support stateful inspection, but in CBAC it depends on inspect rules applied to interfaces, whereas in ZBPF it is integrated into policy actions (inspect, pass, drop).
4. **Security and control:** ZBPF provides stricter and more modular control, since all inter-zone traffic must be explicitly defined. CBAC is less structured and more prone to configuration errors.

In conclusion, although both approaches can enforce the required policy, ZBPF offers a more robust, scalable, and secure solution.

3.4 Protecting a campus network using a ZBPF

3.4.1 Network Topology

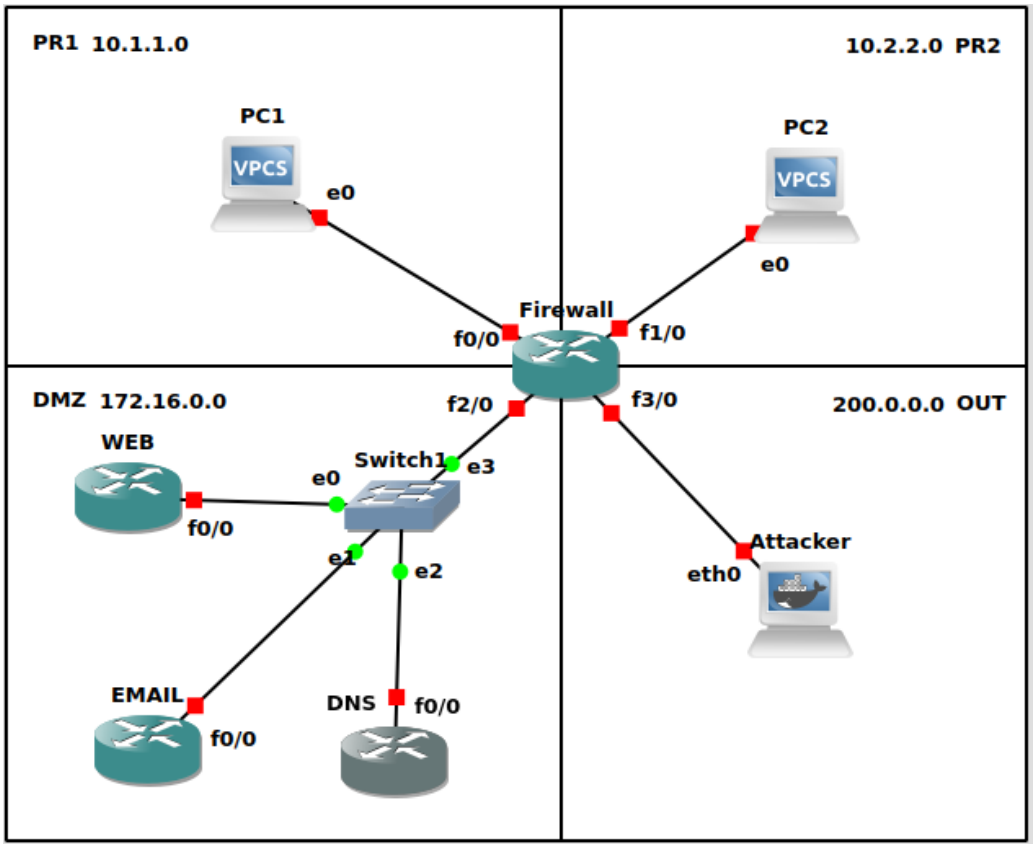

Figure 15: Campus network protected by a ZBPF firewall

The network is divided into four security zones: two private zones (PR1 and PR2), a DMZ, and an external zone (OUT) representing the Internet. The firewall is implemented on a Cisco 7200 router and is responsible for enforcing all security policies between zones.

The DMZ contains three servers providing Web, Email, and DNS services. These servers must be accessible from other zones under controlled conditions, while the private zones must remain isolated from each other and protected from external access.

3.4.2 Initial Configuration and Connectivity

All devices were first configured with IP addresses according to their respective subnets. Default gateways were defined on all hosts, pointing to the firewall interfaces.

The private zones PR1 and PR2 use addressing from the range 10.0.0.0/8, while the DMZ and OUT zones use distinct address spaces.

The routers acting as servers (Web, Email, and DNS) were configured with IP routing disabled using the `no ip routing` command, ensuring they operate as end hosts rather than routers.

Before implementing firewall policies, full connectivity between all devices was verified using `ping`. Additionally, all services (HTTP, HTTPS, DNS, and Email-related ports) were tested to confirm correct operation.

3.4.3 Firewall Configuration

Zone Definition The firewall was configured using a Zone-Based Policy Firewall (ZBPF). Four zones were defined: PR1, PR2, DMZ, and OUT. Each interface of the firewall was assigned to one of these zones.

This approach allows traffic control to be defined explicitly between zones. By default, all traffic between different zones is denied unless a policy is configured, which increases security by enforcing a default deny model.

NAT Configuration Network Address Translation (NAT) with overload was configured to allow hosts in the private zones to communicate with the OUT zone. This translates private IP addresses into a public address, enabling Internet access while hiding internal addressing.

The NAT configuration was applied to both PR1 and PR2 zones.

Policy Definition Traffic policies were implemented using ACLs, class-maps, and policy-maps.

ACLs were used to define which traffic is allowed to specific servers. Separate ACLs were created for the Web, Email, and DNS servers in the DMZ.

Class-maps were used to associate these ACLs with traffic classes. A modular approach was adopted, where individual class-maps were combined into higher-level class-maps representing groups of services.

Policy-maps were then defined to specify the action for each class. The `inspect` action was used to allow stateful communication, while all other traffic was dropped using the default class.

Finally, zone-pairs were created to apply these policies between specific zones, such as PR1-to-OUT, PR1-to-DMZ, and OUT-to-DMZ.

Example Configuration The following example illustrates the policy applied from the OUT zone to the DMZ:

```
ip access-list extended OUT_TO_DMZ
 permit tcp any host 172.16.0.10 eq 80
 permit tcp any host 172.16.0.10 eq 443
 permit tcp any host 172.16.0.20 eq 25
 permit udp any host 172.16.0.30 eq 53
 permit icmp any any

class-map type inspect match-any OUT_DMZ_CLASS
 match access-group name OUT_TO_DMZ

policy-map type inspect OUT_DMZ_POLICY
 class type inspect OUT_DMZ_CLASS
```

```
  inspect
 class class-default
  drop

zone-pair security OUT_TO_DMZ source OUT destination DMZ
 service-policy type inspect OUT_DMZ_POLICY
```

No zone-pairs were defined between PR1 and PR2, nor from OUT or DMZ towards the private zones. As a result, these communications are implicitly denied by the ZBPF default behavior.

3.4.4 Testing and Validation

The following tests were performed:

1. Communication between PR1 and PR2 was tested and correctly blocked;
2. Access from the OUT zone to the private zones was denied;
3. Access from the OUT zone to the DMZ was allowed only for HTTP, HTTPS, SMTP, DNS, and ICMP;
4. Communication from the private zones to the OUT zone was limited to HTTP, HTTPS, DNS, and ICMP;
5. Communication from the private zones to the DMZ was allowed only for the specified services and servers.

3.5 Defense against DoS attacks

4 AAA

4.1 AAA with TACACS+

4.2 AAA with Radius

4.3 802.1X Authentication

5 Conclusion

6 Appendix